FREE TECHNICAL RESOURCE · 2026

Web Application Security Hardening Guide for UAE Businesses

A practical technical guide to hardening your web applications against the OWASP Top 10 — with code examples, configuration snippets, and UAE regulatory context for each control.

OWASP Top 10 2021	NIST SP 800-53	UAE Regulatory Context	Code Examples Included	2026 Edition

© 2026 Nexaguard Cyberlabs FZCO

INTRODUCTION & HOW TO USE THIS GUIDE

This guide is designed for development teams and IT managers at UAE businesses operating web applications. It covers the most critical web application vulnerabilities with practical hardening actions, code examples, and UAE regulatory context for each. Work through each section systematically — use the checklist items as acceptance criteria in your development backlog.

If any item is unknown or not implemented, treat it as a finding and prioritise remediation. Each section includes a risk rating calibrated to the UAE financial and data regulatory context.

OWASP TOP 10 — UAE RISK OVERVIEW

#	VULNERABILITY CATEGORY	RISK RATING	KEY UAE REGULATORY DRIVER
A01	Broken Access Control	Critical	PDPL Art. 8 — data access controls; DIFC DPL
A02	Cryptographic Failures	Critical	PDPL Art. 8 — encryption of personal data at rest/transit
A03	Injection (SQL, Command, LDAP)	Critical	PDPL Art. 12 — breach notification; DIFC DPL
A04	Insecure Design	High	ISO 27001 A.8.25 — secure development lifecycle
A05	Security Misconfiguration	High	NESA IAS-PS-P4 — secure configuration management
A06	Vulnerable & Outdated Components	High	ISO 27001 A.8.8 — vulnerability management
A07	Broken Authentication & Session Management	Critical	CBUAE strong authentication; DIFC/ADGM frameworks
A08	Software & Data Integrity Failures	High	ISO 27001 A.8 — supply chain and SBOM requirements
A09	Security Logging & Monitoring Failures	Medium-High	NESA IAS; ISO 27001 A.8.15 — audit logging
A10	Server-Side Request Forgery (SSRF)	High	Cloud-hosted application exposure (AWS/Azure/GCP)

How to use the code examples: All code examples in this guide are illustrative. Adapt configurations to your specific framework, language, and environment. Have configurations reviewed by a qualified engineer before deploying to production. If you need a formal validation of these controls, **book a Nexaguard VAPT engagement at www.nexaguardcyberlabs.com** — we test against all of these attack classes.

A01

OWASP TOP 10 · MOST EXPLOITED CATEGORY

Broken Access Control

Critical

Attackers access functionality or data they are not authorised to use. Deny-by-default is the single highest-impact control.

HARDENING CHECKLIST

- Implement role-based access control (RBAC) — explicit permission grants, no implicit access
- Deny by default — every request denied unless an explicit permission allows it
- Enforce server-side authorization on every request — never trust client-side controls
- Do not expose direct object references in URLs (use indirect references or GUIDs)
- Log all access control failures and alert on threshold breaches
- Disable directory listing on all web servers and storage buckets
- Test for horizontal and vertical privilege escalation in every release

CODE EXAMPLE — RBAC MIDDLEWARE (NODE.JS)

```
// Deny-by-default middleware function requireRole(role) { return
(req, res, next) => { const user = req.user; if
(!user?.roles?.includes(role)) { // Log the failure
logger.warn('Access denied', { userId: user?.id, role }); return
res.status(403) .json({ error: 'Forbidden' }); } next(); }; } //
Usage: router.get('/admin', requireRole('admin'), ...)
```

UAE Note: PDPL and DIFC data protection requirements mandate appropriate access controls on systems processing personal data. Access control failures exposing personal data may constitute a notifiable breach under PDPL Article 12.

A02

OWASP TOP 10 · PDPL ARTICLE 8 BASELINE REQUIREMENT

Cryptographic Failures & Data Exposure

Critical

HARDENING CHECKLIST

- Enforce TLS 1.2 minimum across all services — disable TLS 1.0 and 1.1 entirely
- Never transmit sensitive data in URL parameters, query strings, or GET requests
- Encrypt all sensitive data at rest — AES-256 minimum for personal and financial data
- Never store plaintext passwords — use bcrypt, scrypt, or Argon2
- Avoid MD5 and SHA1 for any cryptographic purpose — use SHA-256 or better
- Implement certificate pinning for high-value mobile applications
- Manage and rotate encryption keys — never hardcode in source code or repositories

TLS CONFIGURATION (NGINX)

```
ssl_protocols TLSv1.2 TLSv1.3; ssl_ciphers ECDHE-ECDSA-AES256-GCM-
SHA384: ECDHE-RSA-AES256-GCM-SHA384: ECDHE-ECDSA-CHACHA20-
POLY1305; ssl_prefer_server_ciphers on; ssl_session_timeout 1d;
ssl_session_cache shared:MozSSL:10m; ssl_stapling on;
```

UAE Note: PDPL Article 8 requires technical measures to protect personal data — encryption of personal data at rest and in transit is a baseline expectation. DIFC and ADGM frameworks mirror this requirement for financial services entities.

A03

OWASP TOP 10 · PREVENTABLE BUT CONSISTENTLY UNDERIMPLEMENTED

Injection — SQL, Command, LDAP

Critical

HARDENING CHECKLIST

- Use parameterised queries / prepared statements exclusively — never string-concatenated SQL
- Validate and sanitise all user input at the server side — never trust client data
- Use allow-list input validation where possible (reject anything not explicitly allowed)
- Apply least privilege to all database accounts — no app account should have DROP/ALTER
- Suppress SQL error messages in production — log them internally, never expose to user

PARAMETERISED VS. VULNERABLE QUERY

```
// ✗ VULNERABLE — never do this db.query( "SELECT * FROM users
WHERE id = " + userId // SQL injection here ); // ✓ SAFE —
parameterised query db.query( "SELECT * FROM users WHERE id = $1",
[userId] // safely bound parameter );
```

UAE Note: SQL injection breaches exposing customer data require notification under PDPL Article 12. Financial services firms under DIFC or CBUAE oversight face additional regulatory exposure and potential licence implications.

A05

OWASP TOP 10 · LEADING CAUSE OF CLOUD DATA EXPOSURE IN UAE

Security Misconfiguration

High

HARDENING CHECKLIST

- Disable all unnecessary features, ports, services, and default accounts before deployment
- Set all security headers: CSP, X-Content-Type-Options, X-Frame-Options, HSTS, Referrer-Policy
- Enforce HTTPS everywhere — redirect all HTTP to HTTPS, HSTS with long max-age
- Configure CORS explicitly — restrict allowed origins to known trusted domains only
- Audit cloud storage permissions — S3/Azure Blob/GCS buckets default-public is catastrophic
- Remove test/debug endpoints and stack traces before production deployment

SECURITY HEADERS (NGINX)

```
add_header Strict-Transport-Security "max-age=31536000;
includeSubDomains" always; add_header X-Content-Type-Options
"nosniff" always; add_header X-Frame-Options "DENY" always;
add_header Content-Security-Policy "default-src 'self'; script-src
'self'" always; add_header Referrer-Policy "strict-origin" always;
```

UAE Note: NESA IAS-PS-P4 requires secure configuration management across all systems. Cloud misconfiguration is the leading cause of unintended data exposure in UAE businesses — public S3 buckets are discovered regularly.

A06

OWASP TOP 10 · ISO 27001 ANNEX A.8.8

Vulnerable & Outdated Components

High

HARDENING CHECKLIST

- Maintain a Software Bill of Materials (SBOM) for all production applications
- Run dependency scanning in CI/CD (npm audit, Snyk, OWASP Dependency-Check)
- Define patch SLA — Critical CVEs within 7 days, High within 30 days
- Subscribe to CVE alerts for all core frameworks and libraries in production
- Remove unused dependencies — every package is potential attack surface
- Do not run end-of-life frameworks or runtimes in production environments

GITHUB ACTIONS — DEPENDENCY SCAN

```
name: Dependency Audit on: [push, pull_request] jobs: audit: runs-on: ubuntu-latest steps: - uses: actions/checkout@v4 - name: Audit dependencies run: npm audit --audit-level=high --output=json
```

UAE Note: ISO 27001 Annex A.8.8 requires management of technical vulnerabilities. In Nexaguard VAPT engagements, outdated components are among the most frequently cited High and Critical findings across UAE applications.

A07

OWASP TOP 10 · PRIMARY ENTRY VECTOR IN UAE BEC INCIDENTS

Broken Authentication & Session Management

Critical

HARDENING CHECKLIST

- Enforce MFA for all admin, privileged, and high-value accounts
- Implement account lockout after N failed attempts — with alerting
- Rotate session tokens on every login and logout event
- Set session expiry — idle timeout (15–30 min) and absolute timeout
- Store passwords with bcrypt / scrypt / Argon2 — never MD5 or SHA1
- Implement credential breach detection (HaveIBeenPwned API integration)
- Never transmit session tokens in URL parameters

SECURE COOKIE CONFIGURATION

```
# Secure HTTP response cookie headers Set-Cookie: session=TOKEN; HttpOnly; # no JS access Secure; # HTTPS only SameSite=Strict; # no CSRF Max-Age=3600; # 1 hour Path=/ # Argon2 password hashing (Node.js) const hash = await argon2.hash( password, { type: argon2.argon2id } );
```

UAE Note: CBUAE Open Banking and payment regulations require strong customer authentication. DIFC and ADGM-regulated entities should reference their specific authentication requirements — MFA is typically mandatory for administrative access.

A09

OWASP TOP 10 · NESA IAS & ISO 27001 A.8.15 REQUIREMENT

Security Logging, Monitoring & Incident Response Readiness

Med-High

Average dwell time before breach detection is measured in weeks. Without structured logging, you cannot detect, respond to, or evidence what happened — breach notification under PDPL requires this evidence.

HARDENING CHECKLIST

- Log all authentication events — both success and failure with context
- Log all access control failures and input validation rejections
- Never log sensitive data — no passwords, session tokens, or PII in log files
- Centralise logs — use a SIEM or log aggregation platform (not local files)
- Set threshold alerts for anomalous behaviour — high error rates, unusual access patterns
- Retain logs for minimum 12 months — PDPL breach notification may require historical evidence
- Test alerting quarterly — confirm alerts fire correctly with a controlled test event

STRUCTURED LOG FORMAT (JSON)

```
{ "timestamp": "2026-04-30T09:15:00Z", "event": "auth.failure",
"severity": "WARN", "user_id": "u_4821", "ip": "192.168.1.45",
"attempt": 3, "endpoint": "/api/auth/login", "result":
"blocked_lockout" // Never log: passwords, tokens, PII }
```

UAE Note: NESA IAS and ISO 27001 Annex A.8.15 require audit logging. PDPL breach notification obligations under Article 12 require you to demonstrate when and how a breach occurred — logs are the primary evidence.

MASTER HARDENING CHECKLIST — QUICK REFERENCE

HARDENING CONTROL	DOMAIN	RISK	STATUS
Implement RBAC with deny-by-default on all endpoints	Access Control	Critical	○ ○ ○
Parameterised queries — zero concatenated SQL	Injection	Critical	○ ○ ○
MFA enforced on all admin and privileged accounts	Authentication	Critical	○ ○ ○
Secure cookie flags: HttpOnly, Secure, SameSite=Strict	Authentication	Critical	○ ○ ○
Full security headers suite deployed on all responses	Misconfiguration	High	○ ○ ○
TLS 1.2+ enforced — TLS 1.0/1.1 disabled on all services	Cryptography	Critical	○ ○ ○
Personal data encrypted at rest — AES-256 minimum	Cryptography	Critical	○ ○ ○
Dependency scanning running in CI/CD pipeline	Components	High	○ ○ ○
Centralised structured logging — auth and access failures	Logging	Medium	○ ○ ○
Cloud storage permissions reviewed — no default-public buckets	Misconfiguration	High	○ ○ ○
SBOM maintained — all production dependencies inventoried	Components	High	○ ○ ○

VALIDATE YOUR CONTROLS

Done the self-assessment? Now get a professional view.

A Nexaguard VAPT engagement validates these controls against real-world attack techniques — using the same methods your adversaries use. We produce a compliance-ready report suitable for ISO 27001, DIFC, ADGM, and PCI DSS evidence requirements.

Book a Free VAPT Discussion | **www.nexaguardcyberlabs.com**

+971 50 623 3538

Dubai Digital Park, Dubai Silicon Oasis, UAE

This guide is for informational purposes and does not constitute a formal security audit. Technical configurations should be adapted to your specific environment and validated by a qualified practitioner. © 2026 Nexaguard Cyberlabs FZCO. IFZA Freezone Registered Entity, Dubai, UAE.